

# Trust by Construction for Secure Agentic Workflows in Learning Institutions

Rachana (Gen) Srivastava

UNU Macau AI Conference 2026 | Extended abstract

## Problem and contribution

Agentic AI can help learning institutions retrieve records, prepare decisions and coordinate services. Models can also retain sensitive context, delegate work and initiate consequential changes. Fluency does not confer authority to change or disclose student records. Institutions therefore need an architecture that remains enforceable when an acting model is mistaken, manipulated or pursuing an unintended objective.

Trust by Construction addresses this problem by separating model proposals from institutional authority. It presents an executable reference architecture in which protected reads, effects and releases require independently checked task authority. The contribution is the composition of capability control, data lineage, independent approval, durable revocation and failure-aware delivery across one workflow. It builds on complete mediation, least privilege and information-flow security [1,2], and complements system-level prompt-injection defences such as CaMeL [3]. Its purpose is to make guarantees inspectable and falsifiable, without claiming a new alignment algorithm or general proof of agent safety.

## Technical design

An AI Workload Passport declares the ceiling on data classes, tools, destinations, processing zones, delegation, budgets and permitted effects. A Task Contract narrows that ceiling to one purpose, subject, resource set and expiry. The effective capability envelope intersects those declarations with identity, current policy, data lineage, ancestor scopes and remaining budget. Delegated agents receive subsets of their parents' authority, while shared budgets prevent spawning from multiplying rights. Long-lived service credentials remain outside the model process.

The central property is authority non-expansion. If  $A(s)$  is the set of protected operations independently permitted by trusted state  $s$ , and  $O(s,m,r)$  is the set admitted for model proposals  $m$  and reviewer findings  $r$ , the required invariant is  $O(s,m,r) \subseteq A(s)$ . Trusted state includes approvals, revocation epochs, resource versions and budgets, and is refreshed at each boundary. Models may choose among permitted actions or trigger restrictions; they may not create additional authority. A prohibited operation that succeeds is a counterexample. A monitor refusing useful work is an availability failure, not by itself a violation of this invariant.

The threat model permits adversarial model outputs, injected documents, misleading tool descriptions, contaminated memory and hostile monitor findings. It assumes authenticated operators, protected enforcement code, trustworthy control-state storage and keys outside the model's reach. Deployment must prevent access around mediation through credentials, files or sockets. The local reference process alone does not establish this host boundary.

Enforcement follows the task lifecycle. A context gateway authorises retrieval before protected information reaches the model. A memory gateway controls persistence and reauthorises subsequent reads. Source restrictions propagate through summaries, handoffs and artifacts; transformation does not authorise declassification. Consequential changes use a typed proposal containing canonical resources and a version-bound transition. A deterministic executor validates authority, exact approval, current resource state and replay protection before committing.

Consider a transcript correction. The agent retrieves only the permitted record and proposes a change. One role confirms its source and another approves the exact proposal. The executor rejects stale or revoked authority, and release escrow binds delivery to approved bytes and an authenticated recipient. Every subsequent chunk is

reauthorised. A stop or source quarantine denies the remainder without claiming to recall bytes already received. This example separates authorisation from correctness: reviewers must still determine whether the correction is justified.

## **Failure handling and evidence**

The design treats failure as part of the contract. An emergency stop commits revocation before attempting to record evidence, so logging failure cannot restore authority. Recovery requires a named operator and fresh task authority. An AI monitor can request restriction but cannot approve effects or restore privilege. A compromised monitor can therefore deny service or miss misconduct without becoming an escalation path.

Remote effects require a different contract. An outbound intent is recorded before submission with an operation-bound key. A lost acknowledgement leaves the effect uncertain and blocks dependent work; it is not blindly retried. Authoritative provider lookup can settle status, but lookup alone does not guarantee exactly-once execution. Provider deduplication and settlement semantics remain integration responsibilities. These distinctions prevent a local transaction from being mistaken for an end-to-end guarantee.

The Apache-2.0 reference kernel supplies executable failure tests, domain profiles and a source-bound claim register. Evaluation uses controlled synthetic fixtures, with no student records, human participants or institutional production traffic. Across six profiles, the recorded corpus contains 180 hostile and 58 benign scenarios; mediated execution contains all hostile scenarios and completes all benign ones. These are mechanism checks, not estimates of field effectiveness. Removing each of eight tested controls re-enables its associated harmful operation. Substitution of blind and hostile monitors preserves the tested prohibition, although the hostile monitor eliminates retained benign utility.

A separate experiment examines information carried by permitted release choices, following the confinement problem [4]. Approved content may still reveal a secret through destination, path, timing, size or release count. Across 65,536 secrets, one encoder produces 65,536, two and one distinguishable traces under progressively constrained policies. Their base-two logarithms are 16, 1 and 0 bits. These values describe the trace alphabet of that encoder and observer, not a universal leakage bound. The final policy changes timing and padding as well as release count. Both constrained policies escalate approximately 98.4% of adversarial tasks; a single benign two-release workflow completes. This exposes the cost of restriction without generalising its utility to institutional workloads.

## **Extension and relevance to education**

An institution can extend the reference through a domain profile, a capability contract, a service adapter and a claim-to-test entry. The contract names the protected asset, permitted operation, enforcement point, accountable owner, failure test, evidence artifact and failure response. The adapter must preserve identity, versioning, destination and settlement semantics. New declarations may reuse existing primitives; new enforcement mechanisms require review of the core invariant. Extension therefore has an explicit verification burden rather than an assumption of automatic safety.

A practical teaching exercise pairs valid transcript correction with forged approval, contaminated memory and misleading monitoring. Learners inspect why a request succeeds or fails and distinguish fluent advice, valid sources, legitimate authority and sound decisions. This supports both dimensions of the conference theme: engineering bounded institutional uses of AI, and developing the architectural literacy needed to understand and govern those systems.

The governance connection is concrete. Task contracts document scope and responsibility, executable checks support measurement, and revocation and recovery provide operational responses. Such artifacts can support NIST AI RMF activities [5]; they do not establish regulatory conformity. UNESCO's education guidance motivates preserving human agency and institutional capacity [6], while SDG 4 supplies the wider objective of

inclusive, equitable education [7]. Open interfaces and offline verification may make independent inspection more accessible, but cost reduction, learning gains and equitable outcomes have not been measured.

A qualification process separates local evidence from deployment evidence. Host probes identify control-store permissions, standing credentials and undeclared egress; an unmeasurable condition is not counted as a pass. Transport adapters must preserve approved destinations, verify peer identity, reauthorise redirects and enforce byte limits. Controlled loopback tests exercise these mechanisms, while the promotion decision requires evidence from the intended environment. This prevents a successful demonstration from silently becoming an assertion about a university network.

Institutions must name contract owners, source confirmers, approvers and recovery operators. Independent review requires distinct authority and sufficient capacity. A capability chain verifies that approval occurred; it cannot establish that the reviewer understood the case or avoided a shared model error.

A staged adoption can begin with one bounded workflow and its existing human decision process. Engineers should test benign completion alongside refusal, then compose failures across boundaries: delegation followed by revocation, source quarantine after approval, and a lost acknowledgement after submission. The proposed institutional pilot would examine these operational costs and benefits rather than treating successful unit tests as a substitute for educational evaluation.

## Scope and conclusion

This is an engineering contribution with bounded experimental evidence. It does not evaluate a live frontier-model detector, prove general noninterference, qualify a production host or measure student outcomes. The next empirical step is a governed institutional pilot measuring task completion, refusal reasons, reviewer burden and subgroup outcomes. Trust by Construction provides an inspectable foundation for that work: stronger model capability can be integrated while every protected action remains conditional on independently established institutional authority.

Artifact: <https://github.com/genaiworks/fssai-ra> (Apache-2.0).

## References

- [1] J. H. Saltzer and M. D. Schroeder (1975). The Protection of Information in Computer Systems. *Proceedings of the IEEE*, 63(9):1278-1308. <https://www.mit.edu/~Saltzer/publications/protection/Basic.html>
- [2] D. E. Denning (1976). A Lattice Model of Secure Information Flow. *Communications of the ACM*, 19(5):236-243.
- [3] E. Debenedetti et al. (2025). Defeating Prompt Injections by Design. *arXiv preprint 2503.18813*. <https://arxiv.org/abs/2503.18813>
- [4] B. W. Lampson (1973). A Note on the Confinement Problem. *Communications of the ACM*, 16(10):613-615.
- [5] National Institute of Standards and Technology (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1. <https://doi.org/10.6028/NIST.AI.100-1>
- [6] UNESCO (2023). Guidance for Generative AI in Education and Research. UNESCO, Paris. <https://unesdoc.unesco.org/ark:/48223/pf0000386693>
- [7] United Nations General Assembly (2015). Transforming Our World: The 2030 Agenda for Sustainable Development. Resolution A/RES/70/1. <https://sdgs.un.org/2030agenda>